

Course Name: Ethical Hacking	Code: ITA1408	CO: CO1
------------------------------	---------------	---------

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – Assignment

CO1: Understand the core concepts related to malware, hardware and software vulnerabilities and their causes.(BL3)

Assessment Tool Weightage: 5%

Marks :20Marks

Questions

1. A final-year engineering student uses **Nmap** to scan the network of a local software company to identify open ports and running services. The student does not obtain permission from the company before performing the scan. Although no systems are compromised and no data is stolen, the company's security team detects the activity and reports it to the cybercrime cell. As a cybersecurity professional, analyze whether the student's actions are ethical and legal. Discuss the relevant provisions of the Information Technology (IT) Act, 2000, identify the possible legal consequences, and explain the correct procedure the student should have followed before conducting the security assessment.
2. A cybersecurity researcher discovers a **SQL Injection vulnerability** in a popular e-commerce website that could allow attackers to access customer information. Instead of privately informing the organization, the researcher immediately publishes the vulnerability details and proof-of-concept code on social media. Before the company can fix the issue, cybercriminals exploit the vulnerability and compromise customer data. Analyze this incident from both ethical and legal perspectives. Explain the concept of responsible vulnerability disclosure, discuss the risks of premature public disclosure, and recommend the appropriate steps the researcher should have taken.
3. An employee of a financial organization receives an email that appears to be from the company's IT support team requesting immediate password verification. Believing the email to be genuine, the employee submits login credentials through the provided link. The attacker uses these credentials to gain unauthorized access to confidential company data. Examine this case and identify the type of cyberattack involved. Discuss the legal implications for the attacker under the Information Technology (IT) Act, explain the responsibilities of both the organization and the employee, and recommend effective technical and organizational measures to prevent similar attacks in the future.
4. A cybersecurity student discovers a serious security vulnerability in the online banking portal of a private bank. The bank does not have a public bug bounty or vulnerability disclosure program. To demonstrate the severity of the issue, the student exploits the vulnerability and retrieves a small amount of customer information before reporting the findings to the bank. Although the student had no intention of causing harm, the bank initiates legal proceedings. Critically evaluate whether the student's actions are ethical and lawful. Differentiate between ethical hacking and unauthorized hacking, discuss the applicable provisions of the Information Technology (IT) Act, and explain the proper process for reporting vulnerabilities when an organization has no official disclosure policy.

Code of Conduct:

I B. Muni chandini (192524283) (Name / Reg. No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: B. Muni chandini

Nmap Scan without Permission

Scenario

- * A final year engineering student used Nmap to scan a software company's network.
- * The student did not get permission before scanning.
- * No systems were hacked and no data was stolen.
- * The company's security team detected the scan and reported it to the cybercrime cell.

Ethical Analysis

- * The student's action is not ethical.
- * Ethical hackers must always get permission before testing any system.
- * Scanning without permission violates professional ethics.
- * Even if the intention is to learn, authorization is necessary.

Legal Analysis (IT Act, 2000)

- * Section 43 : unauthorized access or use of a computer system is not allowed.
- * Section 66 : unauthorized access done dishonestly is a punishable offence.
- * The company can file a complaint because the scan was performed without permission.

Possible Legal consequences

- * cybercrime investigation
- * legal notice from the company
- * Fine or punishment if found guilty.
- * Damage to the student's academic and professional reputation.

correct procedure

- * Get written permission from the company
- * clearly define the scope of testing.
- * perform only the approved security tests.
- * keep all findings confidential
- * submit a security report to the organization.

Conclusion

- * using Nmap without permission is unethical and may be illegal.
- * ethical hacking is legal only when proper authorization is obtained before testing.

2) SQL Injection Vulnerability Disclosure

Scenario

- * A cybersecurity researcher found a SQL injection vulnerability in an e-commerce website.
- * Instead of informing the company privately, the researcher posted the vulnerability details and proof-of-concept code on social media.
- * Before the company fixed the issue, attackers exploited it and stole customer data.

- * Loss of customer trust and company reputation
- * Increased cybersecurity risk for users.

Recommended steps

- * contact the company's security team privately.
- * provide complete vulnerability details.
- * wait until the vulnerability is fixed
- * publish the research only after receiving permission or after the issue is resolved.
- * follow responsible disclosure guidelines.

conclusion

- * Responsible vulnerability disclosure protects both the organization and its customers.
- * Researchers should always report vulnerabilities privately before making them public.

3) Employee Falls for fake IT Support Email

Scenario

- * An employee received an email that looked like it was from the company's IT support team.
- * The email asked the employee to verify the password immediately.
- * The employee believed the email and entered the login credentials.
- * The attacker used those credentials to access confidential company data.

Ethical Analysis

- * The researcher's action is not ethical
- * security researchers should first inform the organization privately.
- * Publicly sharing the vulnerability before it is fixed puts users at risk.
- * The main goal should be to improve security, not expose the system to attackers.

Legal Analysis

- * publishing exploit details may help cybercriminals outdo the website.
- * The attackers who stole customer data can be punished under the IT Act, 2000 for unauthorized access and data theft.
- * The researcher may also face legal issues if the public disclosure directly leads to damage.

Responsible Vulnerability Disclosure

- * Inform the organization privately about the vulnerability
- * Share all technical details confidentially.
- * Give the organization enough time to fix the issue
- * publish the vulnerability only after the problem has been resolved.

Risks of premature public disclosure

- * Hackers can exploit the vulnerability immediately.
- * customer information may be stolen.
- * financial loss to the company

Type of cyberattack

- * This is a phishing Attack
- * It is also called credential phishing because the attacker steals the users login credentials using a fake email.

Legal Implications (IT Act, 2000)

- * Section 43: Unauthorized access to a computer system
- * Section 66: computer related offences done dishonestly
- * Section 66C: Identity theft by using another person's login credentials.
- * Section 66D: cheating by personation using computer resources.

Responsibilities of the Organization

- * provide regular cybersecurity awareness training
- * enable multi factor authentication
- * Install email security and spam filters.
- * monitor suspicious login activities
- * follow strong password policies.

Responsibilities of the employee

- * check the Sender's email address carefully.
- * Do not click unknown or suspicious links.
- * never share passwords through email.

Conclusion

- * This incident is a phishing attack caused by a fake email.
- * Both the organization and employee must follow good cybersecurity practices to prevent such attacks.

student exploits Banking Vulnerability

scenario

- * A cybersecurity student found a serious security vulnerability in a private bank's online banking portal.
- * The bank did not have a bug bounty or vulnerability disclosure program.
- * To prove the vulnerability, the student accessed a small amount of customer information.
- * The student then reported the issue to the bank.
- * The bank started legal action against the student.

Ethical Analysis

- * The student's intention was to help the bank.
- * However, accessing customer information without permission is not ethical.
- * ethical hackers should never access confidential data without authorization.

Ethical hacking vs unauthorized hacking

Ethical hacking

- * permission is taken from the owner
- * follows legal rules.
- * protects the system
- * Reports findings responsibly

unauthorized hacking

- * NO permission is taken
- * illegal activity
- * Accesses system without authorization
- * May violate user privacy and security.

Legal Analysis (IT Act, 2000)

- * Section 43 : unauthorized access to a computer system.
- * section 66 : computer related offences involving unauthorized access.
- * section 72 : Breach of confidentiality and privacy.

Proper process for Reporting vulnerabilities

- * DO not access or copy customer data
- * collect only enough evidence to prove the vulnerability
- * Report the issue privately to the bank.
- * keep the information confidential.
- * Give the bank enough time to fix the vulnerability.
- * publicly disclose the issue only after it has been resolved, if appropriate.

Conclusion

- * The student's intention was good, but the action was not lawful because there was no permission.
- * Ethical hacking is legal only with proper authorization.